



Air University
(Mid-Term Examination: Spring 2026)
National Cyber Security Academy

Student Name: Ramla Khan
Subject: Cyber Security and Governance
Course Code: CY303
Class: BS VI (A,B)
Section: (A, B)

Student ID: 231268
Total Marks: 50
Date: 3-4-2026
Duration: 2 Hours
FM Name: Dr. Balawal Shabir

Instructions

1. Understanding questions is part of the exam.
2. Return the question paper back.

QUESTION 1: [20 Marks] - CLO 02

You are the newly appointed CISO of a large critical infrastructure provider with converged Information Technology (IT) and Operational Technology (OT) environments. Reflecting strictly on the technical attack vectors and governance failures observed in the 2021 Colonial Pipeline incident, detail the exact initial access mechanisms utilized by the DarkSide actors to infiltrate the network. Following your breach analysis, strictly apply the CISM framework's attack surface discovery principles to formulate a specific mitigation strategy that technically addresses the compromised VPN and exposed External Remote Services (such as RDP), safely manages End-of-Life (EOL) OT assets where vendor patches are unavailable, and implements the precise logical zoning and Zero Trust access management controls mandated to prevent future lateral movement into the ICS network.

QUESTION 2: [15 Marks] - CLO 01

A manufacturing enterprise's CISO is currently failing to secure budget and management buy-in because her governance strategy relies exclusively on operational metrics, such as the "percentage of incoming network traffic evaluated by a firewall" and the "number of vulnerabilities uncovered during automated scans". Contrast this flawed approach against the CISM framework's mandated outcomes of "Strategic Alignment" and "Value Delivery". Explicitly identify why these purely technical metrics fail to resonate with executive leadership, and subsequently propose a highly specific set of SMART (Specific, Measurable, Attainable, Relevant, Timely) metrics that directly quantify the financial impact of security on continuous manufacturing processes and third-party supply chain transactions, exactly as prescribed in the course case study.

QUESTION 3: [15 Marks] - CLO 03

The transition from high-level enterprise strategy to operational execution requires strict adherence to a defined documentation hierarchy to manage risk efficiently. Precisely distinguish the functional differences and rigidities between Policies, Standards, Procedures, and Guidelines within an Information Security Governance framework. In your technical breakdown, evaluate how an enterprise must systematically apply these four

page 1 of 2

structural elements to enforce a "Layered Defense" architecture, specifically detailing how "Non-IT Controls" (such as secure marking, secure storage, and social engineering prevention) are explicitly documented via procedures to mitigate the risk of individual judgment calls and ensure that operations can continue seamlessly even if regular staff are unavailable.

page 2 of 2